

Matriz de Evaluación PRAGMATIC Completa para Métricas CWE

1. Introducción

Esta matriz aplica los criterios PRAGMATIC a un conjunto representativo de métricas propuestas para el marco nacional de indicadores CWE, siguiendo la estructura GQM. [web:21][web:26][web:16][web:24]

Se emplea una escala sencilla:

- A – Alto
- M – Medio
- B – Bajo

Para usos más formales se puede traducir a números (por ejemplo, 3, 2, 1) y sumar un “score PRAGMATIC” por métrica.

2. Tabla de evaluación PRAGMATIC

2.1. Leyenda de criterios

- P: Predictivo
- R: Relevante
- A: Accionable
- G: Genuino
- M: Significativo
- A2: Preciso (Accurate)
- T: Oportuno (Timely)
- I: Independiente
- C: Rentable (Cost-effective)

2.2. Matriz

Métrica	Descripción breve	P	R	A	G	M	A2	T	I	C	Comentarios clave
M1.1	% de vulnerabilidades nacionales mapeadas a CWE Top 25	A	A	M	M	A	M	M	M	M	Necesita repositorio nacional con campos CWE y referencia a Top 25 anual. [web: 28] [web: 27] [web: 9]

M1.2	Distri bució n % de vulne rabili dades por CWE Top 25 y sector	A	A	M	M	A	M	M	M	M	Permi te detect ar perfil es de debili dades sector iales; requi ere buena clasifi cació n sector ial. [web: 9] [web: 14]
M1.3	Ranki ng de las 10 CWE más frecue ntes por sector	M	A	A	M	A	M	M	M	A	Atract iva para comu nicaci ón; sensi bilida d a calida d de datos de base.

M1.4	% de debili- dades de diseñ o frente a imple ment ación	M	A	M	M	M	M	B	M	M	Depe nde de uso consis tente de vistas de CWE (p.ej., CWE- 1000). [web: 7] [web: 22]
M2.1	CVSS medio por CWE en activo s nacio nales	A	A	M	M	M	A	M	M	M	Buen a para priori zar clases de debili dades, pero exige CVSS consis tente. [web: 9] [web: 28]

M2.2	% de vulnerabilidades asociadas a CWE presentes en KEV	A	A	A	M	A	M	M	M	M	Muy útil para priorización táctica; dependiente de la calidad KEV y del mapeo. [web: 2] [web: 9]
M3.1	Tiempo medio de remediación por CWE prioritaria	A	A	A	M	A	M	M	B	M	Puede sesgarse si se “cierran” tickets de manera artificial; requiere definición uniforme de hitos. [web: 9] [web: 14]

M3.2	Varia ción intera nual del volu men de vulne rabili dades por CWE	A	A	M	M	A	M	B	M	A	Prede cible y releva nte, pero sensi ble a cambi os en capac idad de detec ción. [web: 1] [web: 28]
M4.1	% de pliego s TIC públic os que menci onan CWE/ Top 25	B	M	M	A	M	M	B	A	M	Genui no respe cto a madu rez regul atoria , pero limita do como predi ctor técnic o.

M4.2	% de auditorías ENS/ISO/NIS2 que evalúan CWE explícitamente	M	A	M	M	M	B	B	M	M	Depende de criterios de auditor; útil para gobernanza, menos para riesgo inmediato.
M4.3	% de organizaciones que usan CWE como taxonomía formal	M	A	M	M	A	B	B	M	A	Indicador de adopción cultural; se basa en autodeclaración de encuesta.

M4.4	% que mapean sistemáticamente vulnerabilidades a CWE	M	A	A	M	A	B	B	M	M	Muy accio nable (se puede exigir en contr atos), pero depen de de sincer idad de respu estas.
M4.5	% de herra mient as de seguri dad que sopor tan CWE	M	M	M	A	M	A	M	A	M	Fácil de medir vía inven tario; muest ra capac idad técnic a instal ada. [web: 22] [web: 11]

M5.1	IGM (Índice de Gestión de Debilidades) medio nacional	M	A	M	B	A	B	B	B	M	Métrica compuesta; su utilidad depende fuertemente del diseño y pesos.
M5.2	Dispersión del IGM por sector (varianza)	M	M	M	B	M	B	B	B	M	Sirve para ver desigualdad de madurez; menos intuitiva para decisores no técnicos.
M6.1	Nº medio de debilidades CWE por aplicación crítica	M	A	M	M	M	M	B	M	B	Difícil de obtener a gran escala; útil en estudios sectoriales concretos.

M6.2	% de proyectos con revisión de arquitectura centrada en CWE	B	M	M	M	M	B	B	M	M	Métrica de proceso; buena para madurez, pobre predictor directo de incidentes.
M7.1	% de incidentes críticos asociados a CWE del Top 25	A	A	A	M	A	M	M	M	M	Muy potente para ilustrar la “materialización” de debilidades; precisa buena taxonomía de incidentes.

M7.2	% de incidentes con raíz en debilidades de diseño o vs. implementación	M	A	M	M	M	B	B	M	M	Requiere buen análisis post mortem; difícil de automatizar.
M8.1	Nº de profesionales formados en CWE por 1000 empleados TIC	B	M	M	A	M	B	B	M	M	Más cultural que técnico; útil como contexto, no como métrica primaria de riesgo. [web: 8]

M8.2	% de organizaciones con repositorio unificado de vulnerabilidades con campos CWE	M	A	A	M	A	B	B	M	M	Muy accionable (puede convertirse en requisito de mínimos).
M8.3	% de organizaciones que combinan CWE, CVE y CVSS en un mismo cuadro de mando	M	A	A	B	A	B	B	B	M	Refleja un salto de madurez; su coste de implantación no es trivial.

3. Uso de la matriz

Esta matriz permite:

- Seleccionar métricas fuertes (P y R altos, C aceptable) como núcleo de un cuadro de mando nacional. [web:21][web:26]
- Identificar métricas “decorativas” (bajo P, bajo A) y relegarlas a informes secundarios.
- Justificar inversiones: por ejemplo, si una métrica es muy relevante y accionable pero carece de precisión o oportunidad, se argumenta la necesidad de mejorar la infraestructura de datos. [web:24][web:29]

La matriz no pretende clausurar el debate, sino evitar que los indicadores se conviertan en poesía numérica sin capacidad de incomodar decisiones.